

AI IDENTITY SECURITY POLICY

SecureNova Inc.

AI Identity Security Capstone Project

Project 5 — Policy, Compliance and Summary

Prepared by:
Vasavi Suseela Bobba

Date:
23 August 2026

TABLE OF CONTENTS

Contents

1.Identity Lifecycle.....2

2.Cerdential Governance.....2

3.incident Response Playbook.....2

3. Incident Response Playbook

3.1 Purpose

The Incident Response Playbook defines the standard process for detecting, containing, investigating, reporting, and recovering from AI identity security incidents affecting SecureNova's AI-powered customer service platform.

The playbook applies to human identities, AI agent identities, OAuth clients, API keys, M2M credentials, RAG services, MCP tools, and related authentication and authorization components.

3.2 Incident Response Process

Every AI identity security incident shall follow these stages:

1. Detection → 2. Containment → 3. Evidence Preservation → 4. Notification → 5. Recovery → 6. Lessons Learned

Detection

Security alerts, authentication logs, API logs, token activity, anomalous agent behavior, prompt-injection indicators, and unauthorized API calls shall be reviewed to identify suspicious activity.

Containment

The affected credential, user, agent, OAuth client, or API key shall be restricted or revoked to prevent continued unauthorized access.

Evidence Preservation

Relevant logs, timestamps, request IDs, authentication events, token metadata, affected prompts, model responses, and API activity shall be preserved before making destructive changes.

Notification

The security team and appropriate application/system owners shall be notified according to incident severity. Critical incidents shall be escalated immediately.

Recovery

Compromised credentials shall be rotated or revoked, affected identities shall be re-authenticated, malicious data shall be removed, and affected services shall be restored to a trusted state.

Lessons Learned

After recovery, the security team shall document the root cause, impact, controls that failed, corrective actions, and recommendations to prevent recurrence.

3.3 Scenario 1 — Leaked LLM API Key

Incident

An LLM API key used by an AI agent is accidentally exposed through a model response, application log, source-code repository, or prompt-injection attack.

Detection Signals

The following indicators may identify the incident:

- Unexpected LLM API requests from an unknown IP address.
- Sudden increase in API call volume.
- API calls occurring outside the expected application environment.
- An exposed API key appearing in model output or logs.
- Authentication failures followed by successful API requests.
- Unexpected increase in API usage or cost.

Example 1

A prompt injection causes the AI agent to return a simulated credential such as:

JWT/API_KEY_EXPOSED

The security monitoring system detects that credential-like information appeared in the model response.

Example 2

An API key is accidentally committed to a public repository and is subsequently used from an unfamiliar IP address.

Containment

1. Immediately revoke the exposed LLM API key.
2. Generate a new short-lived credential.
3. Block suspicious IP addresses where appropriate.
4. Disable any unauthorized sessions using the compromised credential.
5. Temporarily restrict the affected AI agent if continued compromise is suspected.

Evidence Preservation

Preserve:

- API authentication logs.
- API request timestamps.
- Source IP addresses.
- Agent identity.
- Request IDs.
- Model prompts and responses.
- Token/key metadata.
- Git/repository audit logs.
- Relevant application logs.

Do not delete evidence before the investigation is complete.

Notification

The security team shall notify the application owner and incident-response owner. If customer or sensitive data may have been accessed, the incident shall be escalated according to organizational breach procedures.

Recovery

1. Revoke the compromised key.
2. Generate a replacement credential.
3. Store the new credential in an approved secrets-management system.
4. Update the AI application configuration.
5. Test authentication using the new credential.
6. Review API permissions and reduce unnecessary privileges.

7. Monitor the replacement credential for abnormal activity.

Prevention

- Never place long-lived API keys in prompts or model context.
- Use short-lived credentials where possible.
- Store secrets in a secrets-management system.
- Apply least privilege.
- Scan source repositories for exposed credentials.
- Apply output guardrails to prevent credential-shaped data from being returned.

3.4 Incident Severity

Severity	Description	Response
Critical	Credential compromise with confirmed sensitive-data access or privileged action	Immediate containment and escalation
High	Compromised identity, exposed credential, or successful unauthorized action	Immediate investigation and credential rotation
Medium	Suspicious activity blocked before successful compromise	Investigate and strengthen controls
Low	Security event with no evidence of successful attack	Record and monitor

3.5 Incident Closure

An incident may be closed only after:

- The threat has been contained.
- Compromised credentials have been revoked or rotated.
- Unauthorized access has been investigated.
- Evidence has been preserved.
- Required notifications have been completed.
- Systems have been restored to a trusted state.

- Corrective actions have been documented.

3.4 Scenario 2 — Compromised AI Agent Identity

Incident

An attacker obtains or impersonates an AI agent identity and attempts to access APIs or perform actions beyond the agent's authorized scope.

Detection Signals

Indicators include:

- Unexpected changes in agent scopes.
- An agent requesting privileged operations.
- Requests from an unexpected environment.
- Repeated authorization failures.
- Agent behavior inconsistent with its normal activity.
- Use of an expired or revoked credential.
- Multiple identities appearing to use the same credential.

Example 1

An agent normally has:

read:ai-data

but suddenly attempts to access:

write:admin

The authorization layer rejects the request.

Example 2

An attacker attempts to reuse an old agent token after it has been revoked. The authorization system returns **an invalid_token** or **401 Unauthorized** response.

Containment

1. Revoke the compromised agent credential.
2. Disable the affected agent identity if necessary.
3. Revoke active sessions/tokens.
4. Restrict the agent's API access.
5. Investigate recently executed privileged operations.

Evidence Preservation

Collect:

- Agent identity.
- Authentication events.
- Token issuance and expiration times.
- Requested scopes.
- API requests.
- Authorization failures.
- Source IP information.
- Agent-to-agent communication logs.
- Relevant timestamps and request IDs.

Notification

Notify the security team and the owner of the affected AI agent. Escalate immediately if unauthorized privileged actions or sensitive-data access are confirmed.

Recovery

1. Create a new credential for the agent.
2. Apply the minimum required scopes.
3. Re-authenticate the agent.
4. Verify authorization against each protected API.
5. Review and remove unnecessary permissions.
6. Monitor the agent for abnormal activity.

Prevention

- Use short-lived agent credentials.
- Apply least privilege.
- Require authorization checks for every privileged API request.
- Use cryptographic agent identity binding where applicable.

- Do not trust an agent solely because another agent claims it is trusted.
- Re-verify identity across agent-to-agent communication.

3.5 Scenario 3 — Prompt Injection Leading to Data Exfiltration

Incident

An attacker inserts malicious instructions into user-controlled or retrieved content. The AI agent follows the malicious instructions and attempts to disclose protected information or invoke an unauthorized tool.

Detection Signals

Indicators include:

- Suspicious instructions inside retrieved documents.
- Requests to ignore system instructions.
- Attempts to reveal credentials or system prompts.
- Unexpected tool calls.
- Requests for confidential information.
- Model output containing credential-like strings.
- Unusual data transfer following retrieval activity.

Example 1

A poisoned RAG document contains an instruction attempting to make the AI agent reveal a credential from its context.

Example 2

A malicious document instructs the agent to call an MCP tool and send retrieved information to an unauthorized destination.

Containment

1. Block the malicious request or model response.
2. Stop unauthorized tool execution.
3. Quarantine the malicious RAG document/chunk.
4. Disable affected MCP tools if necessary.

5. Revoke exposed credentials.
6. Restrict the affected agent until investigation is complete.

Evidence Preservation

Preserve:

- Original user prompt.
- Retrieved RAG document/chunk.
- Model input.
- Model output.
- Tool-call records.
- Agent identity.
- Authentication information.
- API requests.
- Timestamps.
- Security-alert records.

Notification

Notify the security team and application owner. Escalate the incident if confidential information was accessed, disclosed, or transferred.

Recovery

- Remove or quarantine poisoned content.
- Validate the RAG knowledge source.
- Review affected model interactions.
- Rotate potentially exposed credentials.
- Restore the agent to a trusted configuration.
- Re-test the affected workflow.
- Monitor subsequent requests for repeated attack behavior.

Prevention

- Treat user-controlled and retrieved content as untrusted.
- Implement input/output guardrails.
- Restrict agent tool permissions.
- Apply least privilege.
- Validate RAG content before ingestion.
- Prevent credential-shaped information from appearing in model responses.

- Log agent and tool activity.

3.6 Incident Severity

Severity	Description	Response
Critical	Credential compromise with confirmed sensitive-data access or privileged action	Immediate containment and escalation
High	Compromised identity, exposed credential, or successful unauthorized action	Immediate investigation and credential rotation
Medium	Suspicious activity blocked before successful compromise	Investigate and strengthen controls
Low	Security event with no evidence of successful attack	Record and monitor

3.7 Incident Closure

An incident may be closed only after:

- The threat has been contained.
- Compromised credentials have been revoked or rotated.
- Unauthorized access has been investigated.
- Evidence has been preserved.
- Required notifications have been completed.
- Systems have been restored to a trusted state.
- Corrective actions have been documented.



